

Feedback Produk - Multi-Provider Object Storage SaaS

Ringkasan

Produk ini feasible, tetapi ruang lingkupnya lebih tepat disebut **multi-cloud object-storage control plane dan data gateway**, bukan sekadar file explorer atau dashboard S3.

Nilai utama produk:

- Pelanggan mendaftarkan beberapa provider S3 atau S3-compatible.
- Aplikasi pelanggan memakai satu API atau satu konfigurasi storage virtual.
- Provider fisik, bucket, credential, penempatan object, quota, dan policy disembunyikan di belakang gateway.
- Hak akses, audit, penggunaan storage, dan rotasi credential dikelola terpusat.

Keputusan awal yang telah disepakati:

- Target: growth-ready MVP.
- Model SaaS: multi-organization atau multi-tenant.
- Dashboard auth: short-lived JWT dan rotated refresh token dalam cookie httpOnly.
- Admin: global platform admin dan organization admin.
- Arsitektur: satu monorepo, tetapi web dan API merupakan runtime terpisah.
- Data plane dapat dijalankan sebagai shared gateway pool atau dedicated gateway untuk tenant enterprise.
- Cross-provider migration untuk current active object wajib masuk MVP; historical version migration ditunda.
- Concurrent overwrite saat migration memakai source fingerprint dan optimistic retry, bukan long-lived write lock.

Evaluasi Fitur

Fitur	Kelayakan	Feedback
Mendaftarkan banyak S3 provider	Layak	Sediakan preset provider dan konektor Generic S3-compatible. Jangan menjanjikan semua provider tanpa compatibility test.
Mengelola bucket	Layak dengan batasan	Mulai dari import bucket yang sudah ada, browse, dan connection test. Operasi destructive seperti delete bucket sebaiknya ditunda.
File explorer	Layak	Gunakan logical namespace dan object index di PostgreSQL. Jangan bergantung hanya pada hasil listing provider.
Hak akses per folder	Layak	Folder S3 adalah prefix, bukan direktori fisik. Policy harus diterapkan pada prefix oleh gateway.
API terpisah per folder/client	Layak	Buat API credential yang terikat ke organization, namespace, prefix, actions, quota, expiry, dan rate limit.
Satu API menyembunyikan provider	Layak	Custom REST API lebih realistis untuk MVP. Full S3-compatible facade adalah fase lanjutan.
Routing file berdasarkan persentase	Layak	Pilih satu target untuk setiap object, simpan hasilnya, dan jangan mengacak ulang saat object dibaca.
Priority dan threshold	Layak	Threshold harus menggunakan configured soft capacity dan internal usage ledger.
Migrasi object antar-provider	Wajib dan layak	Gunakan workflow copy, verify, atomic metadata switch, dan delayed source cleanup. Migrasi harus resumable, idempotent, dan dapat dipantau per object.
Quota per API/client	Layak	Reserve quota sebelum upload dan commit setelah object diverifikasi.
Mengeluarkan S3 config virtual	Layak tetapi kompleks	Memerlukan gateway yang memahami AWS Signature V4 dan perilaku S3, bukan hanya membuat access key dan secret.
OPNsense bandwidth shaping	Berguna tetapi tidak cukup sendiri	Hanya berlaku pada trafik yang melewati OPNsense dan hanya dapat membedakan tenant jika ada identitas jaringan yang berbeda.

Koreksi Konsep Penting

Dukungan provider

Cyberduck mendukung lebih dari S3, termasuk SFTP, WebDAV, OpenStack Swift, dan layanan storage lain. MVP sebaiknya hanya menyatakan dukungan:

- AWS S3.
- Cloudflare R2.
- Backblaze B2 S3-compatible API.
- MinIO.
- Generic S3-compatible endpoint.

Provider lain ditambahkan setelah melewati contract test. Dukungan protokol non-S3 sebaiknya menjadi produk atau adapter fase berikutnya.

Folder adalah prefix

Amazon S3 memiliki struktur object yang flat. Folder adalah representasi dari object key prefix seperti:

```
clients/acme/invoices/2026-07.pdf
```

Grant untuk folder clients/acme berarti gateway mengizinkan operasi pada key yang diawali prefix tersebut.

Untuk MVP, gunakan model allow-only:

- Grant dapat memberi list, read, write, dan delete.
- Tidak ada explicit deny.
- Scope paling spesifik digunakan untuk evaluasi.
- Credential tidak pernah dapat memperluas izin di luar namespace-nya.

Virtual bucket membutuhkan object index

Ketika satu logical namespace memakai beberapa physical bucket, sistem harus mengetahui lokasi setiap object:

```
logical key -> provider -> physical bucket -> physical key
```

Mapping tersebut harus disimpan dalam ObjectRecord di PostgreSQL. Tanpa index ini, gateway harus mencari object ke semua provider dan hasilnya akan lambat serta ambigu.

Konsekuensinya:

- Semua write idealnya melewati gateway.
- Perubahan langsung pada physical bucket dapat menyebabkan metadata drift.
- Reconciliation job wajib tersedia.
- External writes dapat dinonaktifkan secara kebijakan atau hanya didukung sebagai mode advanced.

Migrasi antar-provider adalah fitur wajib

Sistem harus dapat memigrasikan object dari satu S3 atau S3-compatible provider ke provider lain tanpa mengubah logical namespace dan tanpa mewajibkan perubahan integrasi pada client.

Cross-provider CopyObject tidak boleh diasumsikan tersedia. Migration worker harus dapat melakukan streaming dari provider sumber ke provider tujuan dengan bounded memory dan multipart upload untuk object besar.

Workflow minimum:

1. Jalankan compatibility, credential, capacity, quota, dan target health preflight.
2. Buat MigrationRun dan migration item per object agar progres, retry, dan kegagalan dapat dilacak.
3. Salin object ke lokasi kandidat pada provider tujuan tanpa mengubah lokasi aktif.
4. Salin Content-Type dan custom metadata yang portable. Tags, storage class, dan encryption harus dipetakan berdasarkan capability provider tujuan.
5. Verifikasi ukuran dan checksum independen seperti SHA-256. ETag tidak boleh digunakan sebagai checksum universal karena dapat berubah akibat multipart upload, encryption, atau perilaku provider.
6. Pastikan object sumber tidak berubah selama proses copy. Jika version atau fingerprint berubah, ulangi copy sebelum cutover.
7. Dalam transaksi database, ubah active physical location hanya setelah verifikasi berhasil dan catat audit serta outbox event.
8. Pertahankan object sumber selama retention window dan setidaknya sampai seluruh presigned URL lama kedaluwarsa.
9. Hapus object sumber melalui cleanup job setelah reconciliation menyatakan target valid.

Metadata logis seperti organization, namespace, logical key, ukuran, checksum, dan logical createdAt harus tetap. Metadata fisik seperti providerConnectionId, bucketConnectionId, physical key, ETag, provider version ID, storage class, encryption detail, dan provider Last-Modified dapat berubah.

Migrasi harus dapat berjalan tanpa downtime besar:

- Object yang belum dipindahkan tetap dibaca dari provider sumber.
- Object yang sudah cutover dibaca dari provider tujuan.
- Write baru diarahkan ke target migration policy.
- Overwrite dan delete harus memeriksa active location dan object version secara konsisten.
- Kegagalan sebelum atomic switch tidak boleh mengubah availability object.
- Migrasi harus mendukung pause, resume, retry, cancel sebelum cutover, progress visibility, dan laporan kegagalan.

Untuk desain jangka panjang, pisahkan logical ObjectRecord dari satu atau lebih physical ObjectLocation. Hanya satu location yang aktif untuk MVP; location kandidat dan retained source memungkinkan verifikasi, rollback, dan delayed deletion tanpa menjadikan temporary copy sebagai replication permanen.

Failover tidak sama dengan redundancy

Placement engine dapat memilih Provider B ketika Provider A penuh atau tidak sehat sebelum upload dimulai. Namun object yang sudah tersimpan hanya di Provider A tetap tidak tersedia ketika Provider A mengalami outage.

Read availability lintas-provider membutuhkan salah satu dari:

- Replication.
- Secondary copy.
- Erasure coding.
- Migration yang sudah selesai sebelum outage.

Replication tidak disarankan untuk MVP karena memengaruhi biaya, quota, delete semantics, versioning, dan recovery.

Migrasi bukan failover atau replication. Salinan kedua hanya bersifat sementara selama copy, verification, retention, dan cleanup; object tidak dianggap redundant untuk availability kecuali ada fitur replication terpisah.

Weight dan threshold adalah dua konsep berbeda

- Weight menentukan probabilitas atau proporsi penempatan object baru.
- Priority menentukan urutan kelompok provider.
- Threshold menentukan kapan provider tidak lagi eligible.
- Health menentukan apakah provider sementara dikeluarkan dari kandidat.

Contoh:

```
Priority tier 1:  
- Provider A: weight 70, threshold 80%  
- Provider B: weight 30, threshold 85%  
  
Priority tier 2:  
- Provider C: weight 100, threshold 90%
```

Gateway memilih provider sehat yang belum mencapai threshold pada tier aktif, kemudian memakai weighted selection. Hasil pemilihan disimpan permanen pada ObjectRecord.

Jangan membagi satu file antar-provider pada MVP

Satu object sebaiknya disimpan utuh pada satu provider. Membagi file menjadi chunk di beberapa provider akan membutuhkan:

- Manifest.
- Range reconstruction.
- Integrity verification.
- Parallel recovery.
- Erasure coding atau replication strategy.
- Penanganan kehilangan sebagian chunk.

Ini merupakan produk distributed storage yang berbeda dan terlalu besar untuk MVP.

Bandwidth dan OPNsense

Ada tiga masalah yang perlu dibedakan:

Masalah	Kontrol yang tepat
Fairness atau kecepatan Mbps	Application rate limiter dan OPNsense
Total volume GB dan biaya egress	Usage metering, quota, billing, dan alert
Kapasitas sistem	Direct transfer, horizontal gateway scaling, dan backpressure

OPNsense dapat melakukan shaping berdasarkan interface, source/destination IP, direction, dan port. OPNsense tidak mengetahui organizationId atau API key yang berada di dalam HTTPS bila seluruh tenant menggunakan IP dan port yang sama.

Implikasi:

- Shared gateway pool: OPNsense memberi aggregate cap; aplikasi memberi per-tenant limit.
- Dedicated gateway: OPNsense dapat memberi hard cap per private IP atau VIP.
- Presigned direct transfer: trafik tidak melewati OPNsense sehingga tidak dapat di-shape oleh firewall tersebut.

Bandwidth shaping membatasi kecepatan, tetapi tidak menghilangkan biaya untuk total byte yang dipindahkan.

Pro

- Satu integrasi bagi banyak aplikasi pelanggan.
- Mengurangi ketergantungan pada API provider tertentu.
- Centralized credential rotation, access policy, quota, dan audit.
- Memungkinkan optimasi biaya dan kapasitas.
- Mempermudah migrasi antar-provider.
- Dapat ditawarkan sebagai white-label atau embedded storage.
- Mendukung paket SaaS shared, business pool, dan dedicated enterprise.
- Pelanggan tidak menerima provider credential.

Kontra

- Full proxy dapat menimbulkan biaya bandwidth dan compute yang tinggi.
- Compatibility behavior berbeda antar-provider.
- Metadata PostgreSQL dan kondisi physical bucket dapat drift.
- Gateway menjadi titik kritis keamanan dan availability.
- S3-compatible facade penuh jauh lebih kompleks daripada custom API.
- Quota harus aman terhadap concurrent upload dan upload yang tidak selesai.
- Billing storage, request, dan egress lintas-provider tidak seragam.
- Provider outage tidak otomatis diselesaikan tanpa replication.
- Produk menciptakan dependency baru terhadap gateway SaaS.
- Dukungan customer-hosted MinIO di private network membutuhkan connector atau tunnel khusus.

Risiko Prioritas

Risiko	Dampak	Mitigasi awal
Provider credential bocor	Kritis	Envelope encryption, KMS/secret manager, redaction, least-privilege provider key
Tenant data leakage	Kritis	orgId pada semua entity/query, service guards, automated isolation tests
SSRF dari custom endpoint	Kritis	HTTPS only, DNS/IP validation, block reserved ranges, egress policy, no unsafe redirects
Metadata drift	Tinggi	Gateway-only writes, reconciliation, explicit object states
Migrasi parsial atau corrupt	Tinggi	Per-object migration state, independent checksum, atomic location switch, idempotent retry, retained source, reconciliation
Quota race	Tinggi	Transactional reservation, serializable transaction, idempotency
Gateway overload	Tinggi	Streaming, direct upload, concurrency limit, backpressure, horizontal replicas
Provider incompatibility	Tinggi	Capability probing dan provider contract test
Destructive delete	Tinggi	Soft workflow, confirmation, audit, delayed deletion untuk fitur tertentu
OPNsense menjadi bottleneck	Tinggi	Capacity planning, HA, monitoring, multiple gateway pools
Presigned URL disalahgunakan	Sedang	Short expiry, scoped operation, content constraints, audit

Rekomendasi Product Scope

Masuk MVP

- Multi-tenant organization dan member.
- Action-level RBAC.
- Global admin dan organization admin.
- Provider presets dan Generic S3-compatible connector.
- Import existing bucket.
- Logical namespace dengan object index.
- File explorer.

- Prefix-based access grant.
- API credential per client.
- Custom REST storage API.
- Quota reservation dan usage ledger.
- Priority dan weighted placement.
- Cross-provider migration engine dan minimal admin workflow dengan preflight, progress, pause/resume, retry, verification, atomic cutover, rollback window, dan delayed cleanup.
- Health check, retry, cleanup, dan reconciliation.
- Activity log append-only.
- Shared gateway pool dan application-level bandwidth limit.

Ditunda

- Full S3-compatible facade.
- Replication dan erasure coding.
- Lifecycle/versioning normalization.
- Automatic cost-based migration dan advanced bulk migration orchestration.
- Non-S3 protocols.
- Customer-managed encryption keys.
- Private-network connector.
- Dedicated full stack per tenant.

Rekomendasi Model SaaS

Paket	Data plane	Traffic control
Free/Standard	Shared gateway atau presigned direct	Per-tenant app limit dan aggregate OPNsense cap
Business	Shared gateway pool khusus tier	Per-tenant app limit dan OPNsense cap per pool
Enterprise	Dedicated gateway dan stable VIP	App limit dan OPNsense pipe per tenant
Regulated/On-premise	Dedicated full stack	Network, database, dan key isolation penuh

Keputusan yang Masih Perlu Dikunci

- Apakah provider hostname boleh terlihat pada presigned URL?
- Apakah pelanggan boleh memodifikasi physical bucket di luar gateway?
- Apakah quota dihitung sebagai logical bytes atau physical replicated bytes?
- Bagaimana overwrite dan versioning dihitung?
- Apakah delete langsung atau memakai retention window?
- Berapa lama retained source dipertahankan setelah migration cutover?
- Dimensi billing: stored GB, request, egress, dedicated bandwidth, atau kombinasi.
- Apakah Generic S3 endpoint hanya boleh public atau perlu private connector?

Referensi

- Cyberduck protocols: <https://docs.cyberduck.io/protocols/>
- AWS S3 prefixes: https://docs.aws.amazon.com/us_en/AmazonS3/latest/userguide/using-prefixes.html
- AWS S3 object keys: <https://docs.aws.amazon.com/AmazonS3/latest/userguide/object-keys.html>
- Backblaze S3 compatibility: <https://www.backblaze.com/docs/cloud-storage-s3-compatible-api>
- Cloudflare R2 presigned URLs: <https://developers.cloudflare.com/r2/api/s3/presigned-urls/>
- OPNsense traffic shaping: <https://docs.opnsense.org/manual/shaping.html>